

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

Supervisor:
Dr. Bui Van Hieu
Dr. Dang Van Hieu

Abstract

Security Operations Centres are judged on whether a genuine intrusion is caught in time, yet the volume of activity they must inspect far exceeds what the analysts on duty can read. Existing responses each solve part of the problem: signature rules decide quickly but cannot interpret intent, correlation platforms aggregate evidence but still hand humans more candidates than they can work through, and automated playbooks execute reliably only on scenarios someone anticipated. What is left for the analyst—assembling context around an alert and judging it—is exactly the part that does not scale. This thesis proposes SENTINEL, a cognitive two-tier security architecture operating fully air-gapped, which places cheap decisions before expensive ones so that reasoning is spent only where it is needed. Tier 1 is a wire-speed filter—deterministic rules, Welford anomaly scoring, and a Light-GBM gate—resolving baseline stream noise without invoking a language model. Surviving events reach Tier 2, a stateful reasoning agent running a locally hosted quantised model behind cryptographic guardrails. Its context is assembled from the event itself (request line, headers, payload, flow statistics), compressed by log-template mining under an explicit token budget; security knowledge is represented as a retrieval corpus of 433 MITRE ATT&CK entries and 107 NIST SP 800-61r2 procedures, indexed both as dense vectors for semantic similarity and as a sparse BM25 index for exact identifiers, the two rankings combined by Reciprocal Rank Fusion. An output-side check requires every technique the agent asserts to appear in that batch’s retrieved documents, or the verdict is withheld for an analyst. Empirical evaluation on benchmark intrusion datasets demonstrates SENTINEL’s efficiency. Tier 1 and the ML Gate automatically offload **90.6%** of the incoming stream. Because the typical event never reaches the model, the median end-to-end latency falls to **0.88 ms** from **17,174.7 ms** under a single-tier LLM baseline. Delimited Nonce encapsulation neutralizes prompt injection structurally rather than by content recognition, resisting all **678** adversarial samples that the static pre-filter cannot absorb, while HMAC-SHA256 hash-chaining detects every core tampering mode and thereby guarantees audit trail integrity and tamper-evidence—though not, given its symmetric key, cryptographic

non-repudiation—operating on a local workstation. SENTINEL proves that a two-tier hybrid architecture provides a trustworthy and effective paradigm for modern SOC defense.

Acknowledgments

The completion of this Master's thesis would not have been possible without the invaluable support and guidance of numerous individuals and institutions.

First and foremost, I wish to express my deepest gratitude and profound respect to my academic supervisors, Dr. Bui Van Hieu and Dr. Dang Van Hieu. Through their scholarship, precise strategic orientation, and rigorous research ethics, they devoted their time to guiding my critical thinking, offering sharp professional critiques, and inspiring my scientific curiosity throughout this research. Their mentorship has shaped this thesis into a rigorous academic work and established a foundation for my future career in cybersecurity and artificial intelligence engineering.

I am deeply grateful to the Board of Management, the leadership of the FSB School of Business and Technology, and the faculty of FPT University, whose dedicated teaching equipped me with strong theoretical and practical knowledge within a professional research environment. I also thank the Leadership and my colleagues at Department C12, the National Data Center, whose trust, flexible accommodation of my schedule, and operational insights directly informed the design and empirical validation of the SENTINEL system.

Finally, and most cherished of all, I dedicate my deepest gratitude to my beloved family, especially my dear wife and our young child. Their silent sacrifices, patience, and constant encouragement during the countless late nights of system evaluation were my pillar of strength. While every effort has been made to conduct this research with rigor, limitations inevitably remain, and I welcome all constructive feedback from the examination committee and fellow researchers.

Contents

Abstract	i
Acknowledgments	iii
List of Figures	v
List of Tables	v
List of Abbreviations	vii
1 Introduction	1
1.1 Background and Motivation	1
1.2 Objectives, Research Questions, Scope and Contributions	3
1.3 Structure of the Thesis	5
2 Theoretical Background and Literature Review	6
2.1 SOC Operational Realities and Cognitive Bottlenecks	6
2.2 Online Statistical Theory and Tier 1 Machine Learning	6
2.3 Local Large Language Models and Tier 2 Agentic Intelligence	7
2.4 Adversarial AI Security and Cryptographic Log Audit	8
2.5 Overview of Related Research and Research Gaps	9
3 System Design and Technical Implementation	12
3.1 Research Methodology	12
3.2 SENTINEL Architecture Overview and SOC Stack Integration	13
3.3 Tier 1: Wire-speed Filter and Machine Learning Gate	14
3.4 Tier 2: Stateful LangGraph Agent and Threat Memory	16
3.5 Dual-RAG Hybrid Knowledge Retrieval	18
3.6 Adversarial AI Security and Cryptographic Audit Sealing	19
3.7 SOC Dashboard and On-Premises Deployment Architecture	22
4 Experiments and Evaluation	23
4.1 Experimental Setup and Measurement Conventions	23
4.2 RQ1 — Offloading and Filtration Economics	24
4.3 RQ2 — AI Security Guardrails and Forensic Integrity	30
4.4 RQ3 — Stateful Reasoning and Attribution	35
5 Conclusion	43
References	1

List of Figures

Figure 1.	SENTINEL at block level: two tiers separated by cost, with a single escalation path between them. (Source: Author)	13
Figure 2.	Tier 1 expanded. Only the <code>ESCALATE</code> branch reaches Tier 2; every other adjudication terminates here, which is what Chapter 4 counts as offload. (Source: Author)	15
Figure 3.	The Tier 2 agent state-graph, mirroring <code>src/agent/work-flow.py</code> : an acyclic graph with no loops, in which every path terminates in an executed action, an analyst hand-off, or an end of cycle. (Source: Author)	17
Figure 4.	Dual-RAG retrieval and the evidence-anchoring guardrail. The check sits on the output side: it constrains what the model may assert, not what the retriever may return. (Source: Author)	19
Figure 5.	Nonce encapsulation at the input boundary and HMAC chaining at the output boundary. The tail-truncation blind spot is drawn rather than omitted, because it follows from the construction. (Source: Author)	21
Figure 6.	Offload composition on the two streams. The tier carrying the load inverts with the attack base rate. Generated from <code>offload_vs_baserate_{stream,demo}.json</code> . (Source: Author)	26
Figure 7.	Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from <code>latency_benchmark.json</code> . (Source: Author)	28
Figure 8.	Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from <code>robustness_results.json</code> and <code>adversarial_negative_results.json</code> . (Source: Author)	32
Figure 9.	Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)	37
Figure 10.	Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from <code>tier2_decision_results.json</code> . (Source: Author) .	39

List of Tables

Table 1.	Comparative analysis between SENTINEL and existing security defense paradigms	11
Table 2.	Experimental Configuration and Dataset Role Assignment	24
Table 3.	Per-Tier Offload Rate on Two Streams with Different Base Rates . .	25
Table 4.	Throughput of Control Configurations on an Identical 150-Event Stratified Subset	28
Table 5.	Guardrail Layers, Measurement Denominators, and Results	31
Table 6.	Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ slightly and are not interchangeable.	36
Table 7.	Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore not directly comparable with A and F. Generated from <code>ablation_action_scores.json</code>	40

List of Abbreviations

Abbreviation	Full Description
AI	Artificial Intelligence
APT	Advanced Persistent Threat
CTI	Cyber Threat Intelligence
DAPT	Dynamic Advanced Persistent Threat
FAISS	Facebook AI Similarity Search
FPR	False Positive Rate
GGUF	GPT-Generated Unified Format
HITL	Human-in-the-Loop
HMAC	Hash-based Message Authentication Code
LLM	Large Language Model
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
NIST	National Institute of Standards and Technology
RAG	Retrieval-Augmented Generation
RRF	Reciprocal Rank Fusion
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center

Chapter 1

Introduction

This chapter establishes the research context and problem statement of SENTINEL—a Cognitive Two-Tier Architecture automating threat detection and incident response within Security Operations Centers (SOCs)—and states the objectives, research questions, scope, and contributions of the thesis.

1.1 Background and Motivation

Cyber attacks have grown in both volume and sophistication, and the defensive burden they impose has grown with them. A mid-sized Security Operations Centre now ingests millions of log events every day [1], the overwhelming majority of which record ordinary activity. Because the cost of missing an intrusion is far greater than the cost of examining a harmless event, monitoring systems are deliberately tuned toward sensitivity, and false-alarm rates consequently exceed 80% [2]. The asymmetry compounds: every additional sensor raises the alert count, while the number of specialists able to read those alerts stays fixed. The binding constraint of a modern SOC is therefore not the ability to detect. It is the allocation of scarce human attention, which cannot be multiplied by buying more servers.

Against that pressure, defenders currently rely on three layers of countermeasure. At the perimeter, firewalls and intrusion detection systems match traffic against static signatures and deterministic rules, blocking what has been described in advance. Behind them, SIEM platforms centralise telemetry from across the estate and correlate it with rules written by the security team. Above both, SOAR platforms execute pre-programmed playbooks so that a recognised situation triggers a scripted response without waiting for a person [3].

Everything these layers cannot settle arrives on an analyst's queue, and there the work becomes manual: the analyst retrieves the raw log, reconstructs what the source address did before and after the flagged moment, checks the destination against the internal asset inventory, looks up the technique the behaviour resembles, and only then decides whether to block, dismiss, or escalate. Each of those steps is reading and cross-referencing, and reading does not parallelise.

Two weaknesses follow directly, and they are the reasons this thesis exists. The first is **time**. An analyst needs minutes to work through a single alert while the stream arrives continuously, so any queue whose arrival rate exceeds its service rate grows without bound—and the backlog is cleared not by finishing it but by abandoning it. The second is **context**. The evidence that decides a case is frequently spread across many separate records and buried inside long, unstructured text fields, so the decision requires holding a lengthy and heterogeneous context in mind at once. Static rules cannot express that at all, because what is needed is not a pattern to be matched but a judgement to be formed. This is precisely why the existing automation does not lift the burden: signatures and playbooks recognise only what has already been described, they fail against variants outside their descriptions, and while they can classify an event, they cannot explain why it matters. Large Language Models offer exactly the missing capability—reading an event in its context and explaining it in language a person can act on—but placing one directly in an operational data stream introduces three new costs. Each act of reasoning takes seconds while data keeps arriving [4]. The reasoning layer itself becomes a target, because a log field can carry wording an attacker composed deliberately to steer the model [5], and whatever the model concludes must be provably unaltered if it is to serve as evidence. And internal logs typically may not leave the organisation, so the model has to run on site, on finite hardware [6].

The founding observation of this research is the cost gap between two kinds of decision. A decision made by a statistical rule takes less than a millisecond; a decision made by a language model takes seconds. That gap of four to five orders of magnitude makes routing every event through the most expensive tier a systematic waste, when the vast majority of events can be settled by very cheap checks. The objective of this thesis is therefore

to design, build, and empirically evaluate **SENTINEL**, a two-tier architecture built on the principle of *placing cheap decisions before expensive ones*: a fast filtering tier that settles most of the traffic outright, and a reasoning tier called upon only for what remains, operating behind protective guardrails and a cryptographically sealed audit trail, entirely on local infrastructure. What makes this a research problem rather than an engineering one is that each of the three costs above must be *measured*, on real data, with metrics that cannot flatter themselves.

1.2 Objectives, Research Questions, Scope and Contributions

The general objective is operationalised as three research tasks. Each is paired one-to-one with a research question and with the contribution it is intended to produce, and Chapter 4 reports results under the same three headings, so that objective, question, and evidence remain aligned throughout.

First — filtration economics. The objective is to construct a stateless dual-stage filtration pipeline operating at wire-speed, so that the majority of telemetry is resolved at the cheap tier without consuming GPU resources. The corresponding question, **RQ1**, asks: *How can a multi-tiered architecture be designed to autonomously offload security telemetry at wire-speed, thereby addressing the latency bottlenecks and resource consumption inherent in Large Language Models?* The intended contribution is to propose and quantify the principle of placing cheap decisions before expensive ones, and to demonstrate by measurement that the offload rate is **a function of the attack base rate of the stream** rather than a constant of the system—a property not stated explicitly in the related literature.

Second — security of the reasoning layer. The objective is to protect the language model structurally rather than probabilistically, and to seal the forensic record so that any alteration is detectable. The corresponding question, **RQ2**, asks: *What methodologies and security mechanisms can effectively withstand adversarial risks (such as log-substrate prompt injection) to protect the AI’s reasoning flow, while simultaneously ensuring the integrity and tamper-evidence of forensic audit trails?* The intended contribution is a defence based on

Delimited Data Encapsulation with random cryptographic nonces, whose essential property is that it **does not depend on the block rate of any classifier**: encapsulated content is processed as passive text regardless of what it says, unlike probabilistic semantic filters whose effectiveness degrades against novel variants [7].

Third — reasoning, attribution, and human workload. The objective is a stateful reasoning engine that retrieves domain knowledge, cites the evidence it used, and routes to a human the cases that warrant one. The corresponding question, **RQ3**, asks: *How can stateful reasoning capabilities and domain-specific knowledge retrieval be integrated into an AI Agent to automate intrusion analysis, attribute attack techniques, and generate transparent forensic reports, thereby reducing and accurately triaging the workload requiring human analysts?* The intended contribution is to replace rigid SOAR playbooks with a stateful agent over a STIX-aligned MITRE ATT&CK knowledge base, coupled with a deterministic RAG-anchoring guardrail requiring every emitted technique identifier to be present in that batch’s retrieved documents—turning hallucination control from a hope placed in the model into a verifiable architectural constraint.

Scope. The object of study is the SENTINEL architecture itself: a Tier 1 stateless filter, a Tier 1.75 semantic cache, a Tier 2 stateful agent engine running a locally hosted quantised model, a hybrid retrieval system over MITRE ATT&CK knowledge, and the cryptographic controls protecting both. Empirical evaluation rests on **two primary datasets**—CSE-CIC-IDS2018 [8] for wide-area network telemetry and CSIC 2010 [9] for real-world HTTP Layer 7 attacks. Two supplementary sources, DAPT2020 [10] for multi-stage intrusion chains and a synthetic zero-day set, are included as **proof-of-concept evidence only** and support no contribution claim. Adversarial evaluation uses 823 samples partitioned by provenance and never merged: **703 from published corpora** (AdvBench [11], deepset [12], jackhhao [13]) as the headline denominator, 80 author-composed samples, and 40 cross-check samples. The system is deployed on a single local workstation operating fully air-gapped, and automated responses are restricted to blocking IP addresses, logging, or escalating to an analyst; physical infrastructure intervention is out of scope.

1.3 Structure of the Thesis

Chapter 2 systematizes the theoretical foundations and surveys related work to establish the research gap. Chapter 3 states the research methodology and details the technical design of SENTINEL. Chapter 4 presents the quantitative results, organized to follow the three research questions above. Chapter 5 concludes.

Chapter 2

Theoretical Background and Literature Review

This chapter outlines the theoretical principles and literature review underlying the thesis: SOC operational bottlenecks, Tier 1 statistical and machine learning foundations, Tier 2 stateful agent and local LLM architectures, adversarial threats with cryptographic audit mechanisms, and a survey of existing AI Security systems delineating the research gap addressed by SENTINEL.

2.1 SOC Operational Realities and Cognitive Bottlenecks

Section 1 stated the operational consequence; this section states its architectural cause. Security monitoring in modern SOC's aggregates raw telemetry from Next-Generation Firewalls, Intrusion Detection Systems, and Endpoint Detection and Response agents into centralized SIEM platforms [1], at volumes far exceeding human analysis capacity [14]. The aggregation itself is not the problem; the problem is that every device feeding it decides by static signature or deterministic rule, so the only lever available for reducing missed detections is a lower threshold, and a lower threshold produces more alerts rather than better ones [2]. SOAR platforms sit above this and automate the response, but a playbook can only fire on a situation someone has already anticipated [3].

2.2 Online Statistical Theory and Tier 1 Machine Learning

A wire-speed tier imposes a constraint before it imposes a choice of method: whatever establishes the traffic baseline must do so in constant time and constant memory, because an unbounded stream cannot be re-read and a per-key history cannot be held. That constraint

rules out any two-pass formulation of the variance and admits the incremental recurrences of Welford [15], in which the sample mean μ_k and the running sum of squared deviations S_k are carried forward one observation at a time:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

The standard deviation $\sigma_k = \sqrt{S_k/(k-1)}$ therefore remains available at every step, and a Z -score can be evaluated against a baseline that is never stored. Two properties matter downstream: the baseline adapts as traffic shifts, and it does so without a retention window an attacker could wait out. The classification and caching stages built on top of it are detailed in Section 3.3.

2.3 Local Large Language Models and Tier 2 Agentic Intelligence

Running the reasoning tier locally is what makes the data-sovereignty property of this design possible, and it is also what makes memory the binding constraint. The arithmetic is unforgiving: eight billion parameters at half precision occupy roughly 16 GB for the weights alone, before activations and the key-value cache, which already exceeds the 16 GB card this thesis targets. Quantization resolves this by representing each weight on a coarser integer grid instead of a floating-point one, trading a controlled amount of numerical fidelity for a proportional reduction in footprint [16]. In the GGUF Q4_K_M format served through `llama.cpp`, the Foundation-Sec-8B-Instruct model [17, 18] occupies 7–8 GB, which leaves headroom on the same card for the context window and the retrieval index.

To orchestrate reasoning, Tier 2 employs a LangGraph acyclic state graph [19] integrated with Threat Memory. Grounding that reasoning in retrieved evidence rather than in parametric memory [20] raises a question the security domain answers differently from general question answering: the queries here mix free prose with tokens that must match literally, such as technique identifiers, CVE numbers and port values. Dense vector search [21] handles the former and is unreliable on the latter; sparse term matching [22] is the reverse.

Because the two produce scores on incomparable scales, they are combined on **rank** rather than on score, which is the property Reciprocal Rank Fusion exploits [23]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

retrieving context directly from 433 STIX MITRE ATT&CK technique entries and NIST SP 800-61r2 guidance for forensic justification.

2.4 Adversarial AI Security and Cryptographic Log Audit

Integrating LLMs introduces log-substrate prompt injection risks [5], where attackers inject malicious instructions into User-Agent headers or Syslog strings to hijack AI reasoning [7]. The defining property of this vector is that **log content is authored by the attacker**: any defense based on recognising malicious content is an unending race against novel phrasings. Pandey and Bhujang [24] measure exactly this exposure against an LLM analyst assistant and report that the danger is not where intuition places it: blunt instruction overrides are suppressed entirely, while persona hijacking still suppresses **68%** of malicious logs, and context manipulation against a summarisation task succeeds in **96%** of attempts undefended and **38%** even with constrained output. A content-recognition filter tuned against the obvious class therefore leaves the effective classes open, which is the empirical case for defending the vector structurally instead. To neutralise the vector structurally, SENTINEL applies Delimited Data Encapsulation with random nonce tags isolating raw inputs, combined with deterministic guardrails constraining outputs to three valid actions (BLOCK_IP, LOG, AWAIT_HITL).

To protect forensic records, the system uses HMAC-SHA256 signature chaining [25] to seal audit records with a local secret key, producing a tamper-evident audit trail. The scope of this guarantee must be stated precisely: because HMAC uses a **shared symmetric key**, the mechanism establishes **integrity and tamper-evidence**, but does **not** constitute non-repudiation in the cryptographic sense—that property requires asymmetric signatures. This

boundary is respected throughout the thesis.

2.5 Overview of Related Research and Research Gaps

Artificial intelligence research applied to Security Operations Centers has evolved across three architectural paradigms [26].

Traditional enterprise defense comprises SIEM platforms such as IBM QRadar and SOAR systems such as Palo Alto Cortex XSOAR [1, 3]. These correlate telemetry with static rules and execute predefined playbooks, so they fail on variants the rules do not anticipate. The cost of that rigidity is measured on the analysts: interviewing SOC practitioners, AlAhmadi *et al.* [27] find alarm quality to be the dominant complaint, with participants describing the overwhelming majority of alarms as not worth acting on. The strength of this paradigm is very low latency—precisely the property SENTINEL’s Tier 1 inherits rather than discards.

Retrieval-augmented classification agents are represented by CyberRAG [28], which orchestrates fine-tuned per-family classifiers behind an LLM agent and reports above 94% accuracy per attack class on SQL injection, XSS, and SSTI benchmarks. Its focus is the quality of classification and reporting for events already selected for analysis; it does not address the prior question of which events deserve that analysis, so no wire-speed tier bounds the arrival rate at the reasoning stage.

Multi-agent and governance-aware agents comprise AutoBnB-RAG [29], LanG [30], and Policy-Guided Threat Hunting [31]. They should not be flattened into one description, because they differ in exactly the dimension this thesis measures. AutoBnB-RAG evaluates retrieval-augmented multi-agent incident response inside the *Backdoors & Breaches* tabletop environment—a study of coordination under simulated incidents rather than of an event-processing pipeline. LanG is the closest prior work: it is likewise LangGraph-based with human-in-the-loop checkpoints, reports ≈ 21 ms inference and a machine-side mean time to detect of **1.58 s**, and—contrary to any claim that such systems are undefended—

already ships a two-layer guardrail combining regular expressions with a Llama Prompt Guard 2 semantic classifier at **98.1%** F1. Policy-Guided Threat Hunting likewise places non-LLM stages first, using a reconstruction autoencoder and a two-layer deep reinforcement learning triage ahead of LLM contextual analysis.

The gap is therefore narrower, and more honest, than an absence of capability in prior work. Each requirement below is met somewhere: cost tiering by Policy-Guided Threat Hunting, prompt-injection defense by LanG, local operation by several. What no single architecture assembles is the **combination**—(1) resolving the majority of telemetry at the statistical/ML tier under one millisecond, with the offload rate reported as a function of the attack base rate rather than as a constant; (2) stateful reasoning running locally on a 16 GB GPU under a retrieval-anchoring rule that withholds any technique the retrieved evidence does not support; and (3) prompt-injection defense whose guarantee is **structural**—derived from where attacker-authored text is placed relative to the instruction boundary, and therefore independent of payload wording, unlike a probabilistic classifier however well it scores—together with HMAC-SHA256 forensic sealing. Table 1 contrasts SENTINEL against these paradigms.

Table 1. Comparative analysis between SENTINEL and existing security defense paradigms

Evaluation Metric	SIEM / SOAR (QRadar, XSOAR)	LLM agent systems (CyberRAG, LanG, Policy-Guided)	SENTINEL Architecture (Thesis)
Core Technology	Static correlation rules, rigid Python/JS playbooks	Agentic RAG, multi-agent orchestration, DRL triage	Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Operational Goal	Centralized log aggregation and playbook response	Automated incident investigation via LLM reasoning	Resolve traffic at the cheap tier, reserve the expensive tier for cases needing reasoning
Cost Tiering	One cheap tier, no reasoning	Present in some (DRL pre-triage), absent in others; offload not reported against base rate	Two tiers: cheap first, expensive second; offload reported on two base rates
Data Sovereignty	Local enterprise	Local deployment reported; hardware envelope not always stated	100% air-gapped on a 16 GB GPU
Prompt Inj. Defense	Not applicable	Probabilistic classifiers (LanG: regex + Prompt Guard 2, 98.1% F1)	Structural guarantee, independent of payload wording
Forensic Audit	Standard text logs (editable post-compromise)	Not reported	HMAC-SHA256 chain, tamper-evident

Chapter 3

System Design and Technical Implementation

This chapter states the research methodology and then details the architectural design and implementation of SENTINEL: the two-tier execution pipeline, Tier 1 wire-speed filtration and Machine Learning Gate, the Tier 2 agentic reasoning engine and Threat Memory, Dual-RAG knowledge retrieval, adversarial security controls with cryptographic audit sealing, and the local deployment architecture.

3.1 Research Methodology

The thesis follows Design Science Research (DSR): the contribution is an artefact, and the artefact is evaluated by measurement rather than by argument. Three pillars structure the construction. The **statistical and machine learning pillar** supplies wire-speed filtration through Welford $\mathcal{O}(1)$ online statistics for rolling Z -score anomaly detection, followed by LightGBM classification. The **agentic logic pillar** supplies contextual reasoning through a LangGraph state-graph orchestrating a locally hosted language model over hybrid FAISS/BM25/RRF retrieval. The **adversarial security pillar** supplies the defensive boundary, stress-testing prompt injection resilience and verifying forensic log integrity. Efficacy is assessed across five dimensions—classification quality, processing performance, adversarial resistance, explanation coherence scored by an independent judge model, and audit integrity—which map onto the three research questions of Section 1.2 and onto the three result sections of Chapter 4.

Three measurement principles govern every figure reported in this thesis: **the denominator must match the question**, metrics must be **immune to base rate** (MCC and Balanced

Accuracy rather than Accuracy or binary $F1$), and every ratio must be reported **together with its denominator and its measurement coverage**. Their consequences are consequential enough to be worked through where they bite, in Section 4.1.

3.2 SENTINEL Architecture Overview and SOC Stack Integration

SENTINEL enforces a Cognitive Two-Tier Architecture whose core design principle is strict decoupling of work by cost: Tier 1 executes stateless statistical and machine learning algorithms resolving the majority of traffic at wire-speed, while Tier 2 hosts a stateful language model agent performing deep contextual reasoning for complex anomalous events.

Figure 1 presents the architecture at block level only. Raw telemetry from perimeter sources is ingested into a Redis Stream queue and handed to Tier 1, which settles the majority of it outright; only events marked `ESCALATE` continue to Tier 2, and every adjudication from either tier is sealed into the same audit chain. The internal structure of each block is deliberately omitted here and expanded in the section named on the block itself, so that the reader meets one level of abstraction at a time.

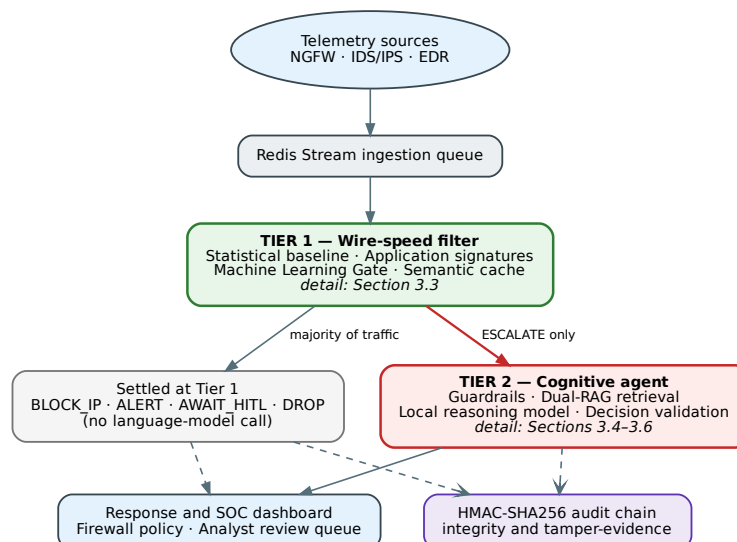


Figure 1. SENTINEL at block level: two tiers separated by cost, with a single escalation path between them. (Source: Author)

One design decision must be stated explicitly: among Tier 1's action vocabulary, **only ESCALATE proceeds to Tier 2**. The adjudications `BLOCK_IP`, `ALERT`, `AWAIT_HITL`, and `DROP` all **terminate at Tier 1**. This is the basis for the offload definition used in Chapter 4: an event counts as offloaded when it generates no language model invocation, regardless of whether the final adjudication was to block or to pass.

At Tier 2, the LangGraph agent triggers a reasoning cycle on the locally hosted Foundation-Sec-8B-Instruct model, integrating historical state from Threat Memory and retrieved evidence from Dual-RAG. Final decisions are governed by a deterministic guardrail bounded to three states, and every record is sealed with an HMAC-SHA256 hash chain. Within an enterprise SOC, SENTINEL therefore acts as cognitive middleware between the SIEM collector and downstream firewall/SOAR execution platforms: it absorbs stream noise at Tier 1 and supplies grounded, cited justifications for escalated events, while guaranteeing data sovereignty through fully air-gapped execution on a single 16 GB VRAM GPU.

3.3 Tier 1: Wire-speed Filter and Machine Learning Gate

Tier 1 is the stateless perimeter layer, combining the Welford $\mathcal{O}(1)$ statistical baseline filter (Equation 2.1) with a LightGBM Machine Learning Gate to guarantee millisecond latency before any GPU invocation. Figure 2 expands the corresponding block of Figure 1.

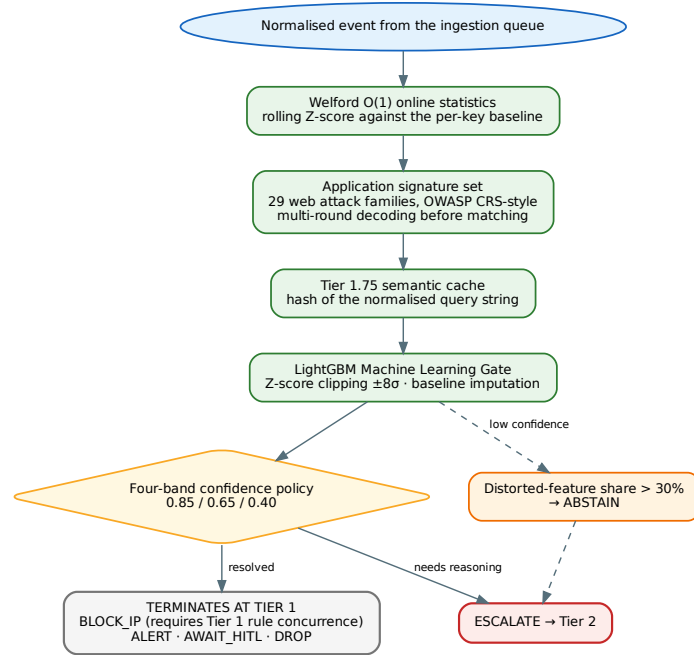


Figure 2. Tier 1 expanded. Only the `ESCALATE` branch reaches Tier 2; every other adjudication terminates here, which is what Chapter 4 counts as offload. (Source: Author)

The statistical filter computes $Z = (x - \mu)/\sigma$ in real time across flow attributes (packet rates, flow volumes, connection durations), with μ and σ updated via the recurrences of Section 2.2 without retaining raw series [15]; traffic conforming to the baseline is shed immediately. Alongside this statistical branch, Tier 1 operates an application signature set covering **30 web attack families** with multi-round normalisation in the OWASP CRS style—decoding URL and HTML entities before matching—to catch payloads disguised by encoding. So that this set is not merely self-declared, each family is anchored to two public reference frames: **23 of the 30** map onto OWASP CRS 3.3 rule files (11 distinct files) and the set spans all **10** OWASP Top 10:2021 categories. The remaining **7** have no CRS counterpart by construction, not by omission—ransomware, cryptomining, credential theft, living-off-the-land binaries and reverse shells are endpoint and network behaviours, outside the scope of a rule set written for HTTP transactions. For repetitive volumetric behaviour, the Tier 1.75 Semantic Cache hashes normalised query strings in RAM and reuses existing adjudications.

A LightGBM Gradient Boosted Decision Tree model follows, evaluating non-linear feature

interactions. It uses leaf-wise growth and is trained on 949,535 NetFlow samples (664,674 training, 189,907 hold-out). To neutralise evasion, the Gate clips feature Z -scores within $\pm 8\sigma$ and imputes missing values with baseline means; if distorted feature proportions exceed 30%, it **abstains** and escalates. Abstention is deliberate: a confident wrong answer is more dangerous than an admission of ignorance, because it causes the system to act autonomously with no one reviewing. Gate adjudications map to actions through a unified **four-band confidence policy** (0.85 / 0.65 / 0.40 for BLOCK_IP / ESCALATE / ALERT / LOG), so that confidence *drives* the action rather than merely accompanying it, and autonomous blocking is isolated to the top band, which additionally requires Tier 1 rule concurrence.

3.4 Tier 2: Stateful LangGraph Agent and Threat Memory

Tier 2 performs stateful cognitive reasoning, executing a Foundation-Sec-8B-Instruct model [17, 18] quantized as described in Section 2.3 and served by CUDA-compiled llama.cpp on a single 16 GB VRAM GPU. Figure 3 expands the Tier 2 block of Figure 1.

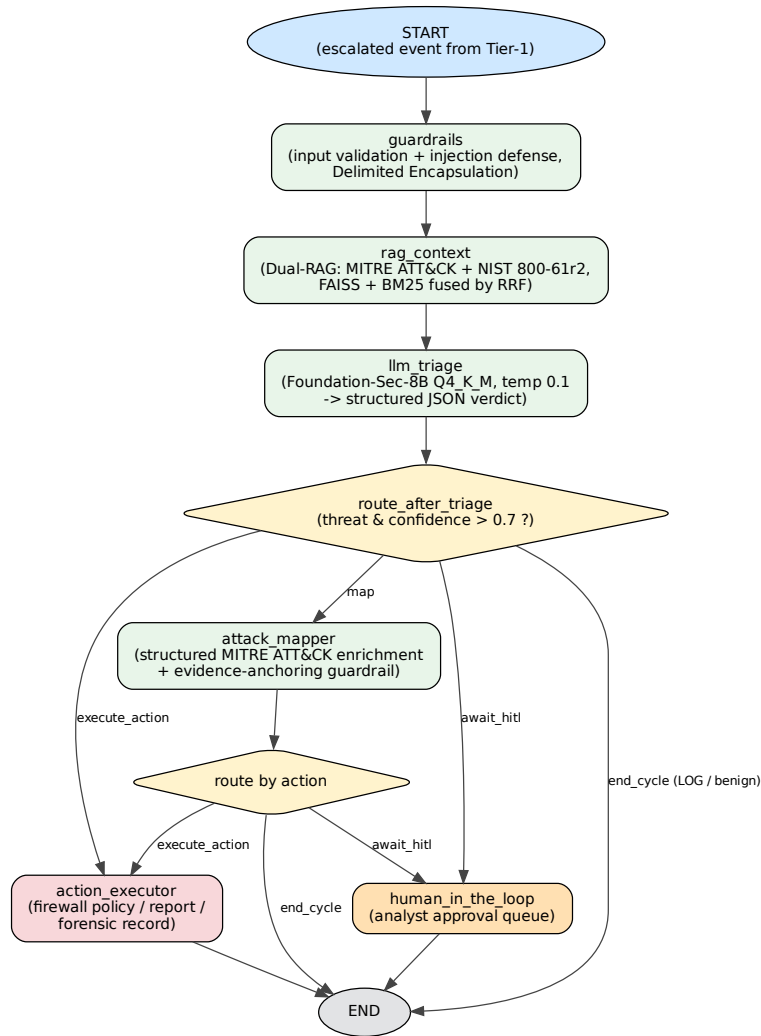


Figure 3. The Tier 2 agent state-graph, mirroring `src/agent/workflow.py`: an acyclic graph with no loops, in which every path terminates in an executed action, an analyst hand-off, or an end of cycle. (Source: Author)

Reasoning is orchestrated by a LangGraph state-graph [19] across five nodes: guardrail inspection, context enrichment (`rag_context`), triage (`llm_triage`), technique mapping (`attack_mapper`), and action execution or hand-off to `human_in_loop`. Technique mapping requires explicit verification from domain knowledge; absent an unambiguous match, the graph routes to analyst review (`AWAIT_HITL`) rather than emitting a speculative action. The human-review path **is a designed output, not a failure**: the system triages the work requiring a human rather than eliminating the human. At `llm_triage` the system performs **label stripping**, removing every internal classification field

from the prompt—a precondition for the validity of every measurement in Chapter 4, since a ground-truth label reaching the context would let the model copy the answer rather than reason to it.

Two controls bound what may enter that reasoning cycle. Repetitive events are first collapsed by **Drain** online log-template mining [32], which groups near-identical records under a shared template so that a burst of a thousand similar lines costs the context window roughly what one line costs. A **token budget monitor** then performs a preflight estimate before each invocation and records the server-reported usage after it, so that approaching the context ceiling is an observed and logged condition rather than a silent truncation. Section 4.3 reports what the pair achieves against a deliberately oversized input.

To correlate traces over time, Tier 2 maintains Threat Memory on an index-optimized SQLite database configured with `synchronous=NORMAL` and `rollback-journal` rather than `WAL`, preventing cross-UID file lock crashes under Docker. It tracks IP reputation (`ip_reputation`), internal entities (`known_entities`), risk indicators (`apt_indicators`), and threat events (`threat_events`). Reputation score S decays over silent period t :

$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.1)$$

where λ is the decay rate. On reaching the maximum ($S = 100$), Tier 1 enforces block-on-sight for subsequent connections without re-triggering Tier 2—closing an automated feedback loop that converts a one-time reasoning cost into a reusable adjudication. Internal infrastructure addresses are whitelisted and immune to blocking, preventing self-DoS.

3.5 Dual-RAG Hybrid Knowledge Retrieval

To limit hallucination and ground security decisions, Tier 2 incorporates a Dual-RAG retrieval system over 433 STIX 2.1-structured MITRE ATT&CK entries [33] and NIST SP 800-61r2 guidance [34]. Retrieval runs two complementary mechanisms: dense semantic search via FAISS [21] with a Sentence-BERT embedding model [35], identifying tech-

niques sharing semantic intent despite keyphrase variation; and sparse keyword matching via BM25 [22], ensuring exact retrieval of identifiers such as CVE codes, Registry keys, or service ports. Candidates are consolidated using RRF (Equation 2.2) with $k = 60$ and injected into the prompt at `rag_context`. Figure 4 shows the retrieval path together with the anchoring check applied to the model’s output.



Figure 4. Dual-RAG retrieval and the evidence-anchoring guardrail. The check sits on the output side: it constrains what the model may assert, not what the retriever may return. (Source: Author)

Retrieval is itself a trust boundary, since a poisoned knowledge entry would be read by the model as authoritative. A **RAG sanitizer** therefore normalises Unicode, strips markup and neutralises imperative constructions in every retrieved passage before it enters the prompt. The difficulty is that legitimate security prose is written in the imperative—advisories instruct the reader to block, disable or isolate—so an over-eager filter silently degrades the knowledge base it is protecting; Section 4.3 reports the false-neutralisation rate measured over the entire corpus.

On top of retrieval the system applies an **evidence-anchoring guardrail**: every technique identifier emitted by the model is checked back against that batch’s retrieved documents, and identifiers absent from them are forced to N/A and routed to `AWAIT_HITL`. This is a **verifiable architectural constraint** rather than a dependency on how prone a given model is to hallucinate—and it is precisely what separates a knowledge-grounded system from a wrapper around a language model.

3.6 Adversarial AI Security and Cryptographic Audit Sealing

Log-substrate prompt injection [5] embeds control instructions inside raw telemetry fields (User-Agent headers, URI parameters, Syslog text) to hijack model behaviour. SENTINEL

implements Delimited Data Encapsulation with a cryptographic nonce regenerated per processing batch [7]: raw telemetry is enclosed within nonce-bearing delimiters, forcing the model to treat the enclosed content as passive data. Per-batch generation—rather than a fixed delimiter—is essential, because an invariant delimiter can be inferred from source code or repeated observation, at which point an attacker can close the encapsulation and escape it. In parallel, three deterministic validators guard the boundaries a language model can reach. The **data validator** rejects malformed telemetry before it is ever framed as a prompt. The **decision validator** enforces Pydantic schema validation (`LLMDecision`), constrains the action to the permitted enumeration, and refuses block orders aimed at internal or reserved address ranges; on formatting errors, regular expression salvaging recovers essential fields or defaults to the safe `AWAIT_HITL` state. The **feedback validator** applies the same zero-trust posture to the rules the system proposes for itself, so that a manipulated adjudication cannot install a permanent rule in Tier 1. Figure 5 places both cryptographic controls on the same diagram, one at each boundary of the reasoning tier.

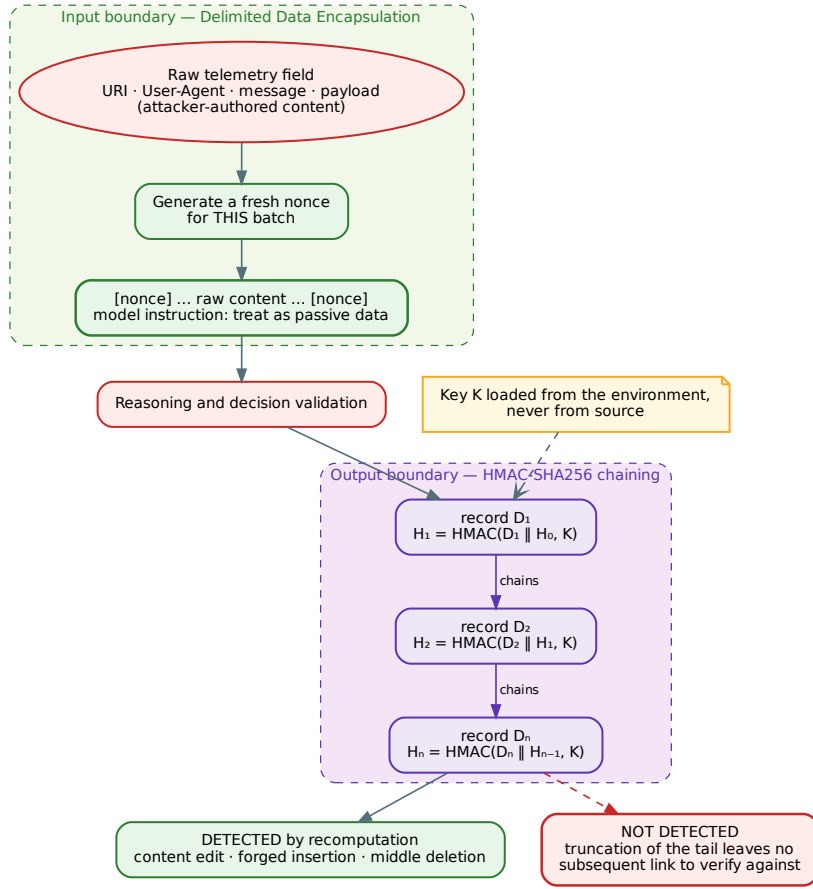


Figure 5. Nonce encapsulation at the input boundary and HMAC chaining at the output boundary. The tail-truncation blind spot is drawn rather than omitted, because it follows from the construction. (Source: Author)

For auditing, each adjudication record i is chained using HMAC-SHA256 [25]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.2)$$

where D_i is the current record, H_{i-1} the preceding hash, and K a local secret key loaded from the environment rather than hardcoded, since a key exposed in source allows the entire chain to be forged from scratch. Chaining ensures any alteration or deletion within the chain breaks continuity and is flagged immediately—guaranteeing integrity and tamper-evidence, though not, for the symmetric-key reason given in Section 2.4, non-repudiation.

3.7 SOC Dashboard and On-Premises Deployment Architecture

The SOC Analyst Dashboard is built with Streamlit, connecting directly to Redis Stream and Threat Memory to provide real-time visibility: the per-tier offload funnel, multi-stage intrusion timelines, HMAC chain integrity status, and the Human-in-the-Loop review panel. Ingestion is rate-limited by backpressure measured as **consumer-group lag**—the number of entries published but not yet claimed by a consumer. The distinction is not cosmetic: because subscribers consume with `XREADGROUP` and `XACK`, neither of which removes entries, stream length stays pinned near its cap however promptly the consumers work, and a producer throttling on stream length would stall permanently against a queue that is in fact empty. All services are containerized with Docker Compose; `llama.cpp` is compiled with CUDA for the RTX 4060 Ti; and `threat_memory.db` with the FAISS index are mounted on persistent volumes so reputation scores and audit records survive restarts.

Deployment adheres to Zero Trust mandates [6]: password strings in `REDIS_URL` are redacted before logging. To manage stream surges, backpressure is driven by **Redis consumer group lag** rather than queue length: a stream's length only grows even when every record has been processed, so throttling on it would strangle the producer permanently, whereas consumer group lag reflects the work actually outstanding.

Chapter 4

Experiments and Evaluation

This chapter presents the quantitative experimental results for the SENTINEL system, organized to follow the three research questions posed in Chapter 1. Each section states the measured metric, the denominator of the measurement, and the limits of the conclusion it supports.

4.1 Experimental Setup and Measurement Conventions

The system is deployed on a local server representative of small-to-medium enterprise SOC infrastructure, with all microservices containerized via Docker Compose in an air-gapped environment. The governing methodological principle is that **the denominator must match the question**: distribution-dependent metrics (offload rate) are measured on the live stream, while classification quality is measured on a class-balanced set. Conflating the two is a serious source of error—measuring offload on a forced 50/50 set yields an artificially low figure, because that set does not reflect the distribution the system actually encounters. Table 2 states each dataset’s role.

Two classes of check are reported outside the metric tables because they are **functional tests, not measurements**: a tier-capability audit confirming that each tier is reachable and behaves as specified (15 of 15 checks pass), and an offload-mechanism audit confirming that each documented offload path actually fires (14 of 14). They answer “is the plumbing connected” rather than “how well does it work”, and reporting a pass rate alongside genuine performance figures would inflate the latter by association.

Two further conventions apply to every run. First, dynamic rules are **frozen** during mea-

Table 2. Experimental Configuration and Dataset Role Assignment

Component	Specification	Role in the Measurement
Processor (CPU)	Intel Core i7	Welford filtering and Redis streams
System RAM	32 GB DDR5	Semantic Cache and FAISS indices
Graphics Card (GPU)	RTX 4060 Ti 16 GB	llama.cpp CUDA, Foundation-Sec-8B-Instruct [18]
Virtualization	Docker Compose	Air-gapped, reproducible environment
<code>datatest.json</code>	4,240 → 4,236 when scored , 51.8% attack	ML Gate classification quality. Drawn from CSE-CIC-IDS2018 [8], CSIC 2010 [9] and DAPT 2020 [10]. Not used for offload rate
<code>ground_truth.json</code>	1,750 samples → 1,700 when scored	Ablation, reasoning quality. 50 author-composed samples excluded from all ratios
<code>build_stream()</code>	25,799 (150 warm-up + 25,649 scored), 31.6% attack	Offload rate, end-to-end
SOC-like stream	99,717 events, 9.8% attack	Offload rate at a near-realistic base rate
Adversarial set	823 = 703 published + 80 author-composed + 40 cross-check	AdvBench [11], deepset [12], and a jailbreak collection [13] whose prompts originate in the in-the-wild study of Shen <i>et al.</i> [36]. The three provenances are scored separately and never merged

surement, preventing a run from generating rules and then benefiting from them later. Second, the 50 author-composed samples embedded in `ground_truth.json` are excluded from all ratios—if retained, they constitute 16.7% of the attribution scoring set and all share a single answer, skewing the label distribution.

4.2 RQ1 — Offloading and Filtration Economics

This section reports **Objective 1 / RQ1** of Section 1.2, under the measurement principles of Section 3.1. RQ1 has three components: offloading at wire-speed, reducing latency, and reducing resource consumption. As stated in Section 3.2, an event counts as **offloaded** when it generates no language model invocation—every action other than `ESCALATE` terminates at Tier 1. This definition matters because a counting scheme crediting only `DROP` omits `BLOCK_IP`, `ALERT`, and `AWAIT_HITL`, none of which consume a single token.

Table 3 reveals a property not stated explicitly in the related literature: **the offload rate is a function of the stream’s attack base rate, not a constant of the system.** Within a

Table 3. Per-Tier Offload Rate on Two Streams with Different Base Rates

Resolving Tier	Benchmark stream, 25,649 ev		SOC-like stream, 99,717 ev	
	Events	Share	Events	Share
Tier 1 (rules + Welford + signatures)	20,663	80.6%	38,207	38.3%
Machine Learning Gate (4-band)	2,568	10.0%	58,992	59.2%
Cumulative — never reaches LLM	23,231	90.6%	97,199	97.5%
Remainder → Tier 2 (LLM)	2,418	9.4%	2,518	2.5%
<i>Attack base rate of the stream</i>		31.6%	9.8%	

single stream the aggregate decomposes linearly as $\text{offload}(p) = (1 - p) \cdot \text{offload}_{\text{benign}} + p \cdot \text{offload}_{\text{attack}}$, where p is the attack rate. On the benchmark stream the two per-label rates are **92.35%** on benign cases and **86.72%** on attack cases, which reproduce the measured 90.6% exactly; on the SOC-like stream they are **97.88%** and **93.77%**, reproducing 97.5%. The coefficients themselves differ between the two streams because the streams differ in composition, so the relation licenses projection to a different base rate **within a stream**—not transfer of one stream’s coefficients onto another. The 90.6% figure is therefore **not an architectural ceiling** but a consequence of a test stream deliberately loaded with more than three times the realistic attack proportion.

A second observation: **the tier carrying the load changes with the stream**. On the benchmark stream, Tier 1 rules resolve 80.6%; on the benign-dominated stream, the ML Gate becomes the primary carrier at 59.2%. The two tiers compensate for one another rather than overlapping—empirical justification for retaining both. Figure 6 makes the inversion visible.

Per-component savings. The ML Gate processes each feature vector in **0.287 ms**, achieving **3,452 events/second**. The Tier 1.75 Semantic Cache achieves an **81.3%** hit rate (1,220 of 1,500 queries) with an **8.9×** speed-up and zero evictions; its key is a hash of the normalised query string—exact match, not embedding similarity—so hits arise because many distinct events reduce to the same service/port/technique description. One quality figure belongs in this section rather than beside it, because it is the guard condition on the offload claim itself: a 90.6% offload rate would read equally well as "passes almost everything" if

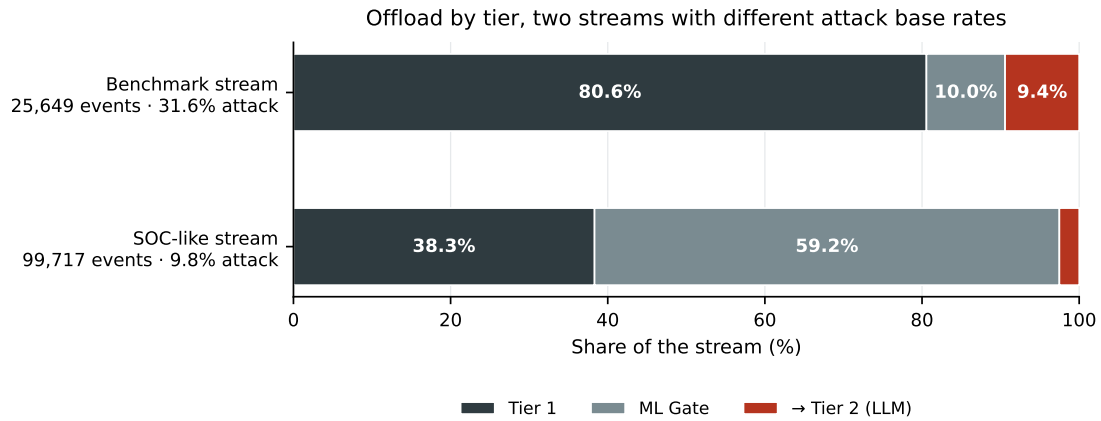


Figure 6. Offload composition on the two streams. The tier carrying the load inverts with the attack base rate. Generated from `offload_vs_baserate_{stream,demo}.json`. (Source: Author)

the offloaded portion were not adjudicated correctly. On `datatest.json` the Gate attains **MCC 0.667** and Balanced Accuracy 0.833—MCC deliberately in place of Accuracy, since a detector answering "benign" everywhere already scores **90.2%** Accuracy on the SOC-like stream while discriminating nothing. The denominator must be stated with the figure: of 4,236 events entering, the Gate adjudicates only **2,534**, a **59.8%** bypass rate—1,586 events lack the payload features the model requires and 116 abstain—so these quality figures describe that adjudicated subset, not the whole file. Its **autonomous blocking** subset of 962 actions achieves **100% Precision with zero false positives**. That last condition is mandatory: offloading that blocks genuine customers is not efficiency but loss.

Tier 2 → Tier 1 feedback loop. A fourth offload mechanism is verified by a two-round experiment on a fixed seed. After harvesting 598 rules from the ML Gate's blocking adjudications, the escalation rate falls from **20.28% to 17.98%** (a relative reduction of **11.35%**, or 594 additional events absorbed by Tier 1), while detection quality **improves** rather than degrades: MCC +0.0378, Recall +0.0452. This is noteworthy because learn-from-adjudication mechanisms typically trade accuracy for speed; here both improve. Two qualifications keep the claim proportionate. The absolute MCC stays low—0.071 → 0.109—so the experiment demonstrates that the mechanism *operates*, not that Tier 1 is a strong classifier. And the simulation is optimistic in two respects: the attacker does not rotate source addresses between rounds, and the analyst approves every proposed rule, with no rejection

step.

End-to-end latency. Latency is measured on 500 events sampled strided from `build_stream()`, preserving the real benign/attack ratio rather than forcing a balanced set. Mean end-to-end latency falls from **17,187.9 ms** (single-tier LLM) to **5,286.7 ms**, a reduction of **69.2%**, with the difference statistically significant under a Mann-Whitney U test ($p \approx 9 \times 10^{-57}$). The median is far more striking: **0.88 ms** against **17,174.7 ms**, a factor of roughly **19,500**—because the typical event never reaches the LLM at all. Per-stage means confirm the cost asymmetry motivating the architecture: **0.182 ms** at Tier 1, **0.924 ms** at the ML Gate, and **22,785 ms** when the LLM is invoked.

One result must be reported against interest: the **95th percentile is worse** for the two-tier system—**25,829 ms** versus **21,434 ms** for the LLM-only baseline. The cause is structural: an event that does escalate has already paid the Tier 1 and ML Gate cost before paying the LLM cost. The tail is therefore genuinely slower, and the architecture’s benefit is concentrated in the median rather than distributed uniformly. Reporting mean and median without the tail would misrepresent the trade-off. Two properties of this particular run must travel with its numbers. Its own offload rate was only **76.8%**—116 of 500 events reached the LLM, not the 90.6% of Table 3—because 500 strided samples never accumulate enough per-address history for the blocklist to engage. And the RAG cache registered **zero hits across 116 lookups**, so the $8.9\times$ cache speed-up reported above is **not** contained within the 5,286.7 ms. For resources, the thesis reports **LLM invocations avoided** (97,199 of 99,717 events) rather than a VRAM reduction percentage, because no VRAM measurement was performed. Figure 7 shows the whole distribution rather than the summary statistics, and the shape carries the argument: the two-tier curve resolves roughly three quarters of events below two milliseconds, then flattens until it meets the baseline in the tail.

Comparison against control configurations. To answer "faster than what", four control configurations are measured on an **identical 150-event stratified subset** (Table 4), rather than importing headline figures from other publications—an invalid comparison across differing datasets and metric definitions.

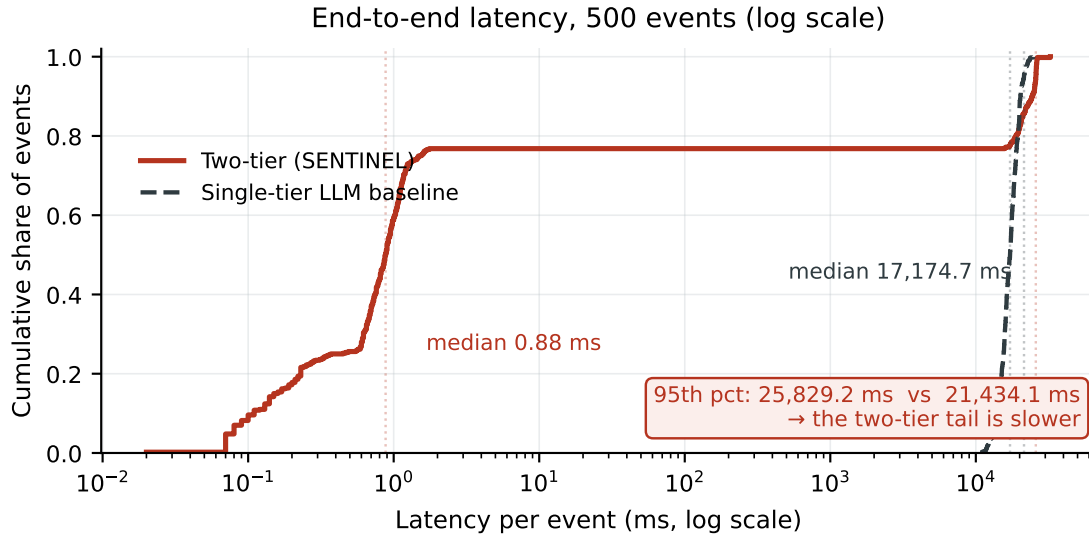


Figure 7. Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from `latency_benchmark.json`. (Source: Author)

Table 4. Throughput of Control Configurations on an Identical 150-Event Stratified Subset

Control Configuration	Throughput
H1 — Static signatures, 30 WAF families	11,129 ev/s
SENTINEL — Tier 1 + ML Gate	3,860 ev/s
H2 — Single-tier LightGBM, flat threshold	2,162 ev/s
H3 — Single-tier LLM (identical data, model, and prompt)	0.19 ev/s

SENTINEL’s deterministic path runs **more than 20,000**× faster than routing every event to the language model (measured 20,531×). Static signatures are faster still, at roughly three times SENTINEL’s rate, which is expected—they perform no statistical or model inference. The ordering *is* the architectural argument in one line: each tier costs what it costs, and the design question is how much traffic can be settled before the expensive one is reached. Two of these figures must not be combined: the 0.19 ev/s routes each event through the **full Tier 2 agent** (797.9 s for 150 events), whereas the 17,187.9 ms baseline is a **bare model call** on the raw log with no token ceiling and no output schema. They describe different single-tier designs, not one measurement in two units. Finally, surge-load testing on the 99,717-event stream confirms that consumer-group lag-based backpressure keeps RAM and VRAM utilisation stable, guaranteeing continuous availability.

Why these thresholds. The four-band policy is not a tuned optimum but a deliberately conservative choice, and a sweep of the operating point shows what it costs. Holding the escalation and alert bands fixed, the block threshold is on a **flat region**: 0.70, 0.75, 0.80 and 0.85 produce identical aggregate quality, and only above 0.90 does recall begin to fall. Choosing 0.85 therefore buys the widest possible margin for autonomous blocking at no measured cost. Across every configuration swept, **autonomous-block precision remains 1.00**. One configuration is aggregate-better—lowering the escalation band to 0.50 raises MCC—but it does so by escalating less, which trades a headline metric for exactly the caution this design exists to preserve.

Detecting the unseen: where the statistical tier saturates. Synthetic anomalies were injected at magnitudes from 2σ to 100σ across seven valid flow features (210 probes per level). Every probe at every magnitude was **escalated**, so nothing passed silently. The statistical *notice*, however, plateaus: the noticed rate rises from 19.52% at 2σ to **42.86%** at 4σ and then **stops**, unchanged through 8σ , 20σ and 50σ , reaching only 54.29% at 100σ . Beyond roughly four standard deviations, making an anomaly larger does not make it more visible to this tier—the limit is the feature set, not the threshold. The practical consequence is that novel behaviour reaches Tier 2 by escalation rather than by recognition, which is the correct failure mode but not a detection claim.

4.3 RQ2 — AI Security Guardrails and Forensic Integrity

This section reports **Objective 2 / RQ2. Threat model and measurement convention.** RQ2 names log-substrate prompt injection as a *typical* adversarial risk, not as the scope. SENTINEL is therefore evaluated against **two structurally different attack surfaces**. The first attacks **through language**: injection and jailbreak text embedded in telemetry fields, aimed at the Tier 2 language model; resistance means the embedded instruction fails to change the agent's action. The second attacks **through feature space**: extreme or infinite values injected into flow attributes to force the LightGBM Gate to answer "benign"; resistance means a distorted sample is still not flipped to benign. A defence covering only the first surface is a narrow defence, since the two tiers are attacked by entirely different means.

Three conventions make the ratios interpretable. First, the static verdict is the logical OR of **three separate detectors**—pattern matching, encoding neutralisation, and delimiter stripping—each recorded individually, so that a failure can be *located* rather than merely counted. Second, a **negative control is mandatory**: the same detectors run over 230 benign logs, because a layer that flags everything also achieves "100% blocking", and a block rate quoted without its false-flag rate is uninterpretable. Third, following Section 4.1, published-corpus and author-composed samples are **scored separately and never merged into one headline**. Table 5 states each guardrail layer with the denominator its result is measured against.

Tier 1 against language. On published corpora the static pre-filter blocks **18.8%**, and that figure must be read together with the **20.0%** false-flag rate on benign logs. Per-detector analysis localises the problem precisely: all 46 false flags originate in the encoding-detection layer, while pattern matching and delimiter stripping produce none—an actionable finding about one layer, not a verdict on the guardrail. The cost of a false flag is also bounded and must be stated, since 20% sounds alarming without it: a static flag raises the isolation level and annotates the record, but does **not** drop the event or block the source. It is therefore a rate of unnecessary annotation, not of benign traffic denied service. The

Table 5. Guardrail Layers, Measurement Denominators, and Results

Guardrail layer	Denominator	Result
<i>Tier 1 — attack through language</i>		
Static pre-filter, published corpora	703 samples	132 → 18.8%
by detector: pattern / encoding / delimiter	703	114 / 29 / 0
Static pre-filter, author-composed	80 samples	58 → 72.5%
Static pre-filter, cross-check set	40 samples	2 → 5.0%
Static pre-filter — false flags on benign logs	230 benign logs	46 → 20.0%
of which: encoding-detection layer	46/46	all of them
<i>Tier 1 — attack through feature space</i>		
ML Gate — evasion, hard mode (all features distorted; 13 flipped, 95% CI 97.86–99.27)	1,036 detected attacks	1,023 → 98.75%
ML Gate — single-feature modes (∞ / extreme)	$1,036 \times 2$	100% both
ML Gate — abstention on distorted input	4,236 events	116 → escalate
<i>Tier 2 — structural guarantee</i>		
Delimited nonce encapsulation	678 hard samples, coverage 100%	678 → 100%
Schema validation under forced backend failure	1 induced failure	AWAIT_HITL, no crash
Determinism (same seed, 5 runs)	5 runs	identical actions
Seed-only variation	10 samples	0 flipped
Context-overflow guard	16,384-token window, 4,000-token budget	worst case 1,655
<i>Forensic integrity</i>		
HMAC — three core tampering modes	30 trials each	100%
HMAC — negative control (intact chain)	450 records	no false alarm
HMAC — tail truncation	—	0% — undetectable

author-composed subset blocks at 72.5%, far above the published figure, and the gap is explained rather than excused: 45 of those 80 samples are encoding-bypass cases and the encoding neutraliser was built precisely for them. Reporting the merged 23.3% would have flattered the system by counting samples written with knowledge of the defence; **18.8% is the figure the thesis stands behind**. Figure 8 places all four rates on one axis, so the block rate cannot be read without its negative control.

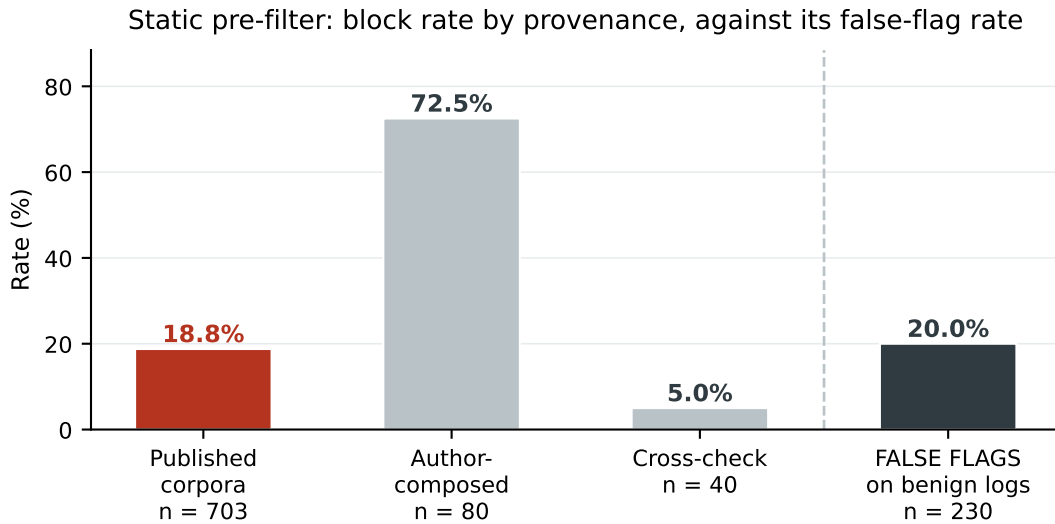


Figure 8. Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from `robustness_results.json` and `adversarial_negative_results.json`. (Source: Author)

Tier 1 against feature space. The ML Gate clips Z -scores to $\pm 8\sigma$, imputes missing values from the baseline, and abstains when the distorted-feature proportion exceeds 30%. Under the **hard mode**, in which *every* feature of a detected attack is driven to an extreme, **98.75%** of samples resist (1,023 of 1,036; 95% CI 97.86–99.27), with 13 flipped to benign. The two single-feature modes reach 100%, and the thesis cites the hard mode rather than an average across all three, because averaging in two trivially saturated modes would inflate the figure past what the defence has actually demonstrated. Abstention is counted as a guardrail outcome, not a failure: 116 events were escalated instead of guessed, since a confident wrong answer causes autonomous action with no one reviewing.

Tier 2 and the categorical difference. The static layer is an inexpensive pre-filter; the security guarantee comes from **Delimited Data Encapsulation**, which is structural—content inside the nonce-bounded region is processed as passive text *regardless of what it says*. It

was evaluated on **all 678 samples of the seven categories the static layer does not absorb**, at **100% coverage** of that set. This is a superset of the 543 samples that genuinely bypassed the static layer within those categories, so the test is stricter than required rather than favourably sampled; Tier 2 resisted **678 of 678**, of which 676 (99.7%) produced an independent language-model call and two collapsed onto a shared cache fingerprint. That is the categorical difference: a classifier blocking $x\%$ always leaks $(100 - x)\%$ and degrades against novel variants, whereas a structural guarantee does not depend on recognising malicious content at all. The 18.8% therefore **does not contradict** the thesis—it quantifies how much work the structural layer must absorb. Two robustness controls support every LLM-dependent measurement in this chapter, and each must be reported with its limit. Under a fixed seed the agent emitted **identical actions** across five runs—but on a **single** sample. Varying only the seed across ten samples flipped **no adjudication**; at $n = 10$ that bounds the flip rate only at **0.2775** (95% CI upper), and all ten returned `AWAIT_HITL` at every seed, so the measurement is saturated on one action and resolves little. These controls therefore make it *unlikely*—not certain—that differences between configurations are decoder noise. A forced backend failure degraded to `AWAIT_HITL` rather than crashing or defaulting to a permissive action.

How tampering is detected. Verification recomputes the entire chain from the genesis record under $H_i = \text{HMAC}(D_i \parallel H_{i-1}, K)$. Because each link consumes its predecessor’s hash, a single byte altered in D_j invalidates *every* link from j onward, so detection is **positional** rather than a bare "something changed". The three core modes map onto the three ways continuity can be broken: a **content edit** makes the recomputed hash at j disagree with the stored one; an **inserted forged record** has no valid predecessor to chain back to; a **deleted middle record** leaves H_{j+1} referencing a hash that no longer exists. All three are detected in 30 of 30 trials, and the negative control over 450 intact records raises no false alarm. The measurement ran with a key loaded from the environment, not the in-source default—a key visible in source would let the whole chain be forged from scratch and would void every rate above. The thesis states the blind spot proactively: **tail truncation is undetectable**, an inherent property of log-chaining, since deleting trailing records

leaves no subsequent link against which to verify. The remedy is periodic anchoring of hash values outside the system.

Guardrails that do not reduce to a single ratio. Several controls defend paths that no block-rate captures. The `RAG_Sanitizer` guards the knowledge base at both ingestion—NFKC normalisation against homoglyphs, removal of control and zero-width characters, HTML/JS and Markdown stripping—and retrieval, neutralising imperative instructions embedded in retrieved documents. Its design carries a measured lesson: an earlier revision matched blocked phrases anywhere in a sentence and consequently rewrote legitimate security prose, neutralising four lateral-movement entries (T1090, T1021, T1021.001, T1553.001) that the thesis’s own APT scenarios depend on. Restricting matches to **imperative position** eliminated this, and re-verification over the current 433-entry knowledge base yields **zero** false neutralisations—the same block-rate-versus-false-flag discipline applied to a layer that publishes no ratio. The `FeedbackValidator` closes the loop opened by the Tier 2 to Tier 1 feedback mechanism of Section 4.2: rules promoted from adjudications pass a field allowlist, pattern validation, and score bounds, because a mechanism that learns from verdicts is also a mechanism for poisoning Tier 1 rules. The `DecisionValidator` enforces the output schema, salvages malformed fields by regular expression, and requires **Tier 1 concurrence** before any autonomous block. A loop detector caps node revisits at ten to stop an agent from circling and consuming GPU time, and an output sanitiser strips base64 and hexadecimal blobs before records reach the database or the dashboard, closing the re-emission path back through the analyst interface.

Field position, tested separately. Because nonce encapsulation wraps **per field**, field position decides whether a payload falls inside or outside the wrapped region—a property no aggregate figure can test, since the other categories all place their payload in the same field. The `field_injection` set of 100 published samples distributes payloads across four positions: URI 24, User-Agent 23, message 30, payload 23. The static layer blocks only 12 of 100, as expected for plain-language injection carrying neither encoding nor delimiters. Run through Tier 2 at **100% coverage**, all 100 resisted, with adjudications distributed as 73 `BLOCK_IP` and 27 `ALERT` and none degraded to a permissive action.

The per-position claim required a second measurement, and the reason is instructive.

On the first run the aggregate looked conclusive and the per-position breakdown looked uniform—but the 100 samples had produced only **79 independent language-model adjudications**. The second-layer cache key was built from `message`, `payload` and `uri` and omitted `user_agent`, so the 23 User-Agent samples collapsed onto **two** fingerprints: two verdicts replayed twenty-one times, in exactly the column the experiment existed to test. A defect in the measurement apparatus and a live cache-poisoning surface were here the same defect, since an attacker in production could equally steer a field absent from the key and be served a stored verdict. Widening the key to cover every application-layer field restored 100 distinct fingerprints, and the experiment was re-run on that basis.

The re-measured result is **uniform across all four positions**—24/24, 23/23, 30/30 and 23/23—now backed by one hundred independent adjudications rather than seventy-nine. The uniformity, not the total, is the finding: had encapsulation been applied to some fields and not others, the unwrapped positions would have surfaced here as a gap. This is reported separately from the 678 because it answers a different question, and the episode is reported at all because the corrected figure is identical to the uncorrected one—which is precisely why a denominator has to be verified rather than assumed.

4.4 RQ3 — Stateful Reasoning and Attribution

This section reports **Objective 3 / RQ3**. RQ3 has four components: ATT&CK technique attribution, knowledge retrieval, transparent reporting, and analyst workload reduction. Each is measured separately below, because they fail for different reasons and one aggregate score would hide that.

Attribution: adding the reasoning tier makes it worse. Attribution is measured twice on an **identical population**—500 payload-layer samples drawn from `ground_truth.json` after the author-composed exclusion, comprising 250 samples carrying a technique label and 250 benign, sourced from CSIC 2010. The first pass runs **retrieval only**: RRF fusion decides the technique with no language model in the loop. The

second runs the **full agent**. Exact-match attribution falls from **80.0%** to **68.0%**, and tactic-level from 80.0% to 70.4%, while median latency rises from **0.54 ms** to **13,293 ms**. The reasoning tier costs four orders of magnitude in time and returns twelve points of accuracy *less* than the retrieval layer it was added to improve.

The loss is explained rather than excused. Of the 30 samples lost, up to **22** are cases where the evidence-anchoring guardrail forced the verdict to N/A because the technique the model proposed was not present in that batch’s retrieved documents. That is a deliberate trade, not a malfunction: the system exchanges attribution accuracy for the guarantee that it never acts on an unsupported identifier. Any figure here must also be read against a floor rather than against zero—T1595.003 accounts for 130 of the 250 labelled samples, so a system always answering that identifier already scores **52%**.

Table 6. Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ slightly and are not interchangeable.

ATT&CK technique	<i>n</i>	Retrieval hit@3	Retrieval only	Full agent
T1190 — Exploit public-facing application	52	1.00	100.0%	63.5%
T1059.007 — JavaScript execution	30	1.00	100.0%	73.3%
T1595.003 — Wordlist scanning	130	0.96	90.8%	86.9%
T1083 — File and directory discovery	12	0.00	0.0%	16.7%
T1071.001 — Web protocols	26	1.00	0.0%	0.0%
All techniques	250	0.93	80.0%	68.0%

Table 6 does what an aggregate cannot: it **locates which tier failed**. For T1083 the retriever never returns the correct document at all, so the fault is in the knowledge base and no downstream component can recover it. For T1071.001 the retriever returns it every single time and attribution is still zero, so the fault is in the mapper. The two require different repairs, and a single 68.0% would have prescribed neither. Figure 9 plots the same three series.

Knowledge retrieval and its ceiling. On the same payload slice—243 queries, seven excluded because Tier 1 did not escalate them—Dual-RAG attains **Recall@3 = 0.930** (95% CI 0.891–0.956), MRR 0.803, and a median rank of 1 when the correct document is found.

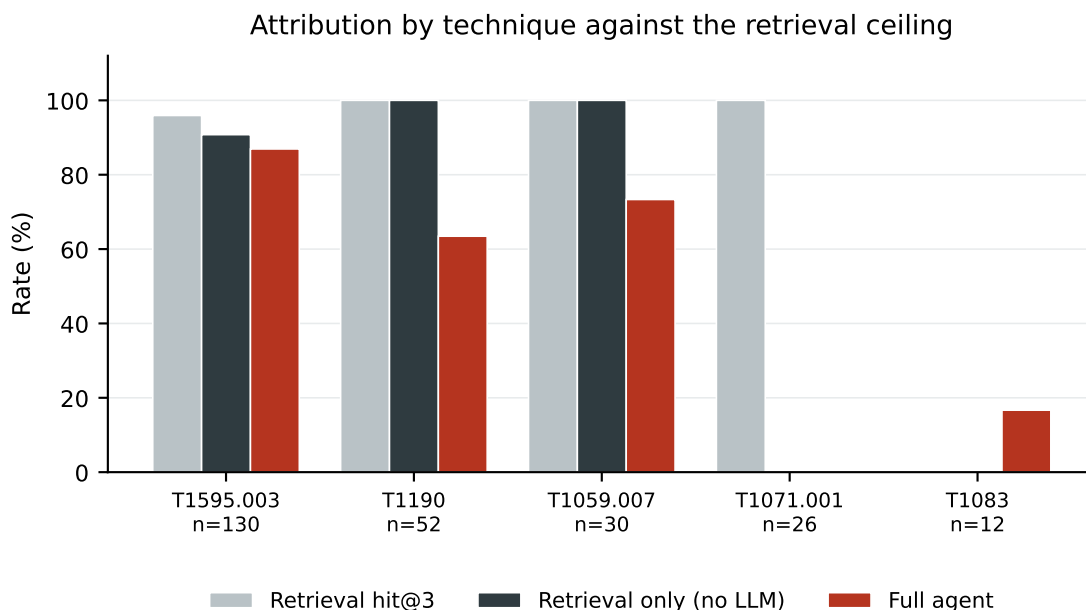


Figure 9. Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)

That is the genuine ceiling of the attribution figures above, and it sits comfortably over them, so the argument closes: retrieval is not what limits the 80.0%. The unfavourable half must be stated with equal clarity. Measured instead over the whole `ground_truth` set of 1,305 queries, Recall@3 collapses to **0.385**, because flow-only samples dominate that population and carry no application-layer text to match against—T1110 scores hit@3 of **0.00** across 236 queries. The two numbers describe **different populations** and 0.385 must never be set against the 80.0%; comparing them would breach the very principle established in Section 4.1.

The anchoring guardrail, measured from execution traces. The evidence-anchoring guardrail (Section 3.5) requires every emitted technique identifier to appear in that batch’s retrieved documents; violations are forced to N/A and routed to `AWAIT_HITL`. Verifying it demands care, because reading only final verdicts would score *any* shield at zero hallucinations—including one that does nothing. The measurement therefore runs on execution traces that record the action *before* and *after* the shield: **1,566 batches**, of which 1,421 asserted a technique. The result is **zero** unanchored assertions (0 of 1,421), and zero even when relaxed to the parent technique. That the shield is doing real work is shown by its

activation count: it fired **145 times (9.26%)**, and in **76** of those it downgraded BLOCK_IP to AWAIT_HITL—meaning **76 automatic, permanent IP blocks were prevented** because the justification could not be anchored. All 76 originated in a technique the model itself proposed; a further 69 activations caught identifiers the mapper had inferred. The most frequently rejected identifiers were T1218 (27), T1083 (24), T1071.001 (16) and T1190 (14). One limit is stated proactively: this score uses the **strict** criterion—the identifier must be among the retrieved document IDs—whereas the deployed shield matches by regular expression across the full context text, so zero is an **upper bound** on shield leakage rather than an exact count.

Triaging the work that reaches a human. This is the component that answers RQ3 most directly, and it produces the chapter’s most negative result. Tier 1 escalated **1,066 alerts**, of which only **80 (7.5%) were genuine threats**; the population is dominated by 910 benign CSIC requests, alongside 75 *cicids*, 76 *cicids_max*, 4 zero-day and 1 adversarial sample. As a binary classifier over that queue the language model is **worthless**: it flagged all 1,066, dismissed **none** of the 986 false alarms, and therefore scores **MCC 0.0**, specificity **0.0** and Balanced Accuracy **0.5**. Within the subset it actively confirmed, the false-positive rate is **99.55%** (894 of 898; 95% CI 98.86–99.83). Its confidence is not merely uninformative but actively misleading—mean confidence when flagging was **0.846** against a true rate of 7.5%, an expected calibration error of **0.803**, and the 900 highest-confidence adjudications were correct **zero** times.

The value sits elsewhere, in the channel the binary framing ignores. The agent deferred **168 alerts** to AWAIT_HITL—**15.76%** of the input—and that queue contains **76 of the 80 genuine threats (95.0%)**, at a true-alert density of **45.24%** against 7.5% at the input. That is a **6.03× enrichment**: an analyst who reviews only the deferred queue examines **84.24% less** material while still seeing 95.0% of the real threats. The operational conclusion follows directly and is stated as a finding rather than a defence: this model is usable as a **triage router** and is not usable as an autonomous confirmer. Nor does MCC 0.0 contradict RQ3 as posed, which asks for reduction and *accurate triage* of the work requiring a human, not for correct verdicts on every alert—and since 910 of the 1,066 escalations were benign

CSIC traffic, the figure also reflects the quality of Tier 1’s escalation decision, not the agent’s alone. For completeness of denominator: 68 of the 1,066 batches were served from cache, leaving **998** independent language-model calls. Figure 10 summarises both channels on one diagram.

Tier 2 alert triage: the value is in the deferral channel, not the verdict

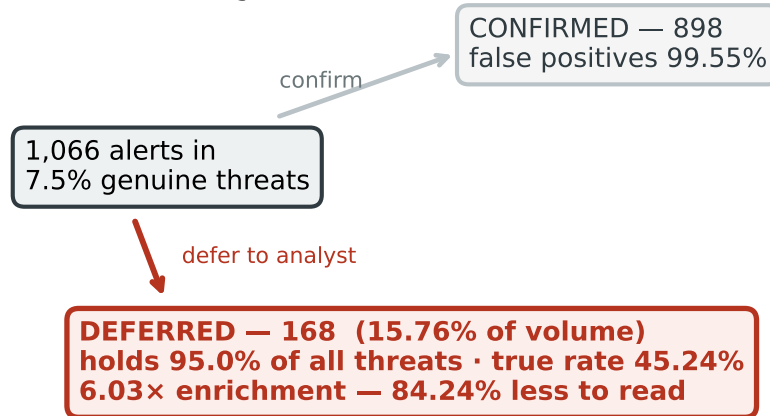


Figure 10. Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from `tier2_decision_results.json`. (Source: Author)

Reasoning quality. Agent justifications are graded by a **cross-family judge** (Meta-Llama-3-8B-Instruct scoring Foundation-Sec-8B-Instruct) on a 1–5 scale along the four axes of the RAGAS retrieval-augmented evaluation framework [37], following the recommended protocol for eliminating Self-Enhancement Bias [38]. The run covers all **1,052** escalated events and is clean in the respect that matters for interpretation: **no adjudication was missing a required field**, and the 71 cases returning no technique identifier were **deliberate abstentions** enforced by the anchoring guardrail rather than parse failures. The four axes score: context precision **2.54**; answer relevancy **4.52**; faithfulness **3.96**; context recall **4.11**; mean **3.78/5.0**.

Two results run against the system and are reported as such. **Context precision at 2.54 is the weakest axis**, corroborating the retrieval diagnosis above: the retrieved set frequently carries entries irrelevant to the event at hand, and the bottleneck is therefore in retrieval rather than in generation. More seriously, **evidence grounding reaches only 11.2%** (95% CI 9.5–13.3), averaging **0.2** verifiable citations per justification—roughly nine justifications in ten quote no log value that can be checked back against the record. This is the

sharpest gap in the architecture between what is *guaranteed* and what is *volunteered*: the anchoring guardrail can prove that an asserted ATT&CK identifier is supported by retrieved documents, but nothing compels the surrounding prose to cite the specific field values that led there. Transparent forensic reporting, the third component of RQ3, is therefore only partially achieved, and closing that gap is a matter of constraining the justification format rather than of improving the model.

Component ablation: what each tier actually contributes. A configuration comparison closes the loop between the design of Chapter 3 and the results reported here. Six configurations are scored on `ground_truth.json`, and the choice of metric has to be justified before the numbers can be read. The binary framing—did the system flag the event or not—is **unusable** on this set: the attack base rate is 86.9%, so every configuration scores close to that figure and the comparison collapses. All configurations previously appeared identical for exactly this reason. Scoring instead on the **final action**—whether the emitted verdict matches the expected one across `BLOCK_IP`, `ALERT`, `LOG` and `AWAIT_HITL`—restores the discrimination the binary metric destroyed. The change of metric is reported here rather than passed over, because a metric selected after seeing results is a metric worth distrusting; the justification is that the binary version is degenerate on this distribution, not that it was unflattering.

Table 7. Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore **not** directly comparable with A and F. Generated from `ablation_action_scores.json`.

Configuration	<i>n</i>	Action acc. (95% CI)	Autonomy	Deferral	Auton. prec.
A — Tier 1 only, no LLM	1,700	28.29% (26.20–30.48)	41.00%	0.00%	69.01%
F — Full two-tier system	1,700	35.35% (33.12–37.66)	55.24%	44.76%	57.72%
B — LLM, no retrieval	300	34.00% (28.87–39.53)	69.67%	30.33%	45.93%
C — + dense retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
D — + sparse retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
E — + rank fusion	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%

Table 7 reports the six configurations. Three findings follow, and the second is the one that matters. First, the reasoning tier earns its cost: the full system reaches **35.35%** action

accuracy against **28.29%** for Tier 1 alone, and the confidence intervals do not overlap, so the gap is not sampling noise. Second, and more informative than the headline, **the trade-off inverts**. Tier 1 alone is the *more* reliable adjudicator whenever it commits—**69.01%** autonomous precision against **57.72%**—but it commits on only 41.00% of events and leaves **59.00% unresolved**, escalating them into a tier that, in configuration A, does not exist. The full system leaves nothing unresolved; it converts that backlog into **44.76%** explicit deferrals to an analyst. The two tiers therefore do not differ in how well they think so much as in **what they do when they do not know**, which is precisely the property Section 4.4 measured from the other direction in the deferral channel.

Third, a null result reported as such: **C, D and E are identical to the digit**. Adding sparse retrieval to dense, and then fusing the two rankings, changes no adjudication on this slice. This is a limitation of the ablation design rather than evidence that the retrieval ladder is inert—all three configurations invoke the language model only on events Tier 1 escalates, so the large majority of the slice falls through to the same `tier1_verdict` regardless of what the retriever would have returned. Isolating the contribution of rank fusion requires an evaluation restricted to escalated events, which is what the retrieval measurement above provides and this ablation does not.

Multi-stage correlation, at the scale the evidence supports. Stateful correlation across a campaign was exercised on nine DAPT2020 chains: all **3 of 3** genuine multi-day chains were reconstructed, and none of the **4** benign multi-day sequences triggered a false campaign alert. The result is reported for completeness and claims nothing: with three positives the 95% confidence interval on recall runs from **0.44 to 1.00**, which is compatible with a system that works and with one that was lucky. Consistent with Section 1.2, multi-stage correlation remains a proof-of-concept capability and is carried into future work rather than counted as a contribution.

Division of labour between tiers. A seemingly negative result confirms the design: on the non-NetFlow sample group (CSIC web attacks, zero-day, DAPT), the ML Gate attains only **11.1% Recall**, and 305 of the full set’s 336 misses fall entirely within this group.

The cause is architectural rather than defective—the ML Gate is trained on **flow features**, whereas web attacks reside in the **payload**, which is exactly the work assigned to Tier 2 and the signature set. The methodological consequence is that the aggregate Recall of 0.755 mixes two non-additive populations and must be reported separately. Relatedly, and as stated in Section 3.4, the escalation-to-analyst rate is **not** a quantity to be minimised: an architecture claiming a zero human-review rate under all conditions has discarded its final guardrail.

Chapter 5

Conclusion

A Security Operations Centre rarely fails because an intrusion went undetected. It fails at the step after detection, where a finite number of specialists must decide which of an effectively unbounded stream of alerts deserves their attention. Language models are the first technology capable of reading an event in its context and explaining it in words a person can act on, yet placing one in an operational data stream imposes costs in time, in trust, and in data sovereignty that no headline accuracy figure addresses. This thesis asked whether that capability can be obtained without paying its full price, and answered the question by building SENTINEL—a two-tier architecture that settles cheap decisions before expensive ones, deployed entirely on a local workstation—and then measuring it rather than describing it. Three results carry the claim.

The economics of tiering hold, and they hold as a law rather than as a single number. Tier 1 and the Machine Learning Gate resolve **90.6%** of a benchmark stream loaded with more than three times the realistic attack proportion, and **97.5%** of a stream at a near-realistic base rate, in both cases without a single language model invocation. Because the typical event never reaches the model at all, median end-to-end latency falls to **0.88 ms** from **17,174.7 ms** under a single-tier baseline. The methodological result matters more than either figure: offload decomposes linearly into a benign-case and an attack-case rate, so it is **a function of the stream’s attack base rate rather than a constant of the system**—a property that lets the measurement transfer to a different environment, and that a single quoted percentage cannot support.

The security guarantee is structural, and therefore does not decay. Delimited Data Encapsulation treats content inside a per-batch nonce boundary as passive text regardless

of what that content says, and resisted **all 678** adversarial samples in the categories the inexpensive static pre-filter cannot absorb—the categories containing precisely the attacks that filter is blind to. This is a different kind of assurance from a classifier that blocks $x\%$ and leaks the remainder against every novel phrasing. Alongside it, HMAC-SHA256 chaining detects **100%** of the three core tampering modes with no false alarm over an intact control chain, sealing the forensic record with integrity and tamper-evidence.

Hallucination control was converted from a hope into a verifiable constraint. Every ATT&CK identifier the system emits must appear in that batch’s retrieved documents; across **1,421** adjudications that asserted a technique, **zero** were unanchored. The guardrail is not inert while achieving this—it fired on 9.26% of batches and, in **76** of them, prevented an automatic permanent IP block whose justification could not be grounded. The same reasoning tier also proved most valuable in a role other than the obvious one: used as a triage router rather than an autonomous confirmer, its deferral queue concentrates **95.0%** of the genuine threats into **15.76%** of the volume, a **6.03×** enrichment that removes **84.24%** of the material an analyst must read.

The architecture’s limits are reported in full where the evidence for them lives, in Chapter 4, and three of them set the immediate agenda: attribution is currently better without the reasoning tier than with it, the agent cannot yet dismiss a false alarm on its own, and the explanation layer is the weakest link—retrieval admits irrelevant material, and only **11.2%** of justifications cite a log value that can be checked back against the record. The corresponding directions are a retrieval layer repaired at the knowledge-base level, calibration of the agent for dismissal as well as confirmation, and a justification format that compels citation rather than merely permitting it. Two smaller extensions follow from properties already stated: periodic anchoring of hash values outside the system would close the tail-truncation blind spot inherent to log chaining, and asymmetric signatures would upgrade tamper-evidence to genuine non-repudiation.

Concluding a rigorous research endeavor, while opening inspiring horizons in securing the digital realm through the power of Agentic Artificial Intelligence.

References

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [4] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [5] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [6] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [7] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [8] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [9] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Marañón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [10] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [11] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [12] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [13] J. Hao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [14] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.

- [15] B. P. Welford, "Note on a Method for Calculating Corrected Sums of Squares and Products," *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [16] A. Gholami *et al.*, "A Survey of Quantization Methods for Efficient Neural Network Inference," *arXiv preprint arXiv:2103.13630*, 2021.
- [17] P. Kastianik, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report," *arXiv preprint arXiv:2504.21039*, 2025.
- [18] S. Weerawardhena, P. Kastianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report," *arXiv preprint arXiv:2508.01059*, 2025.
- [19] LangChain AI, "LangGraph: Multi-Actor, Stateful LLM Applications," *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [20] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [21] J. Johnson, M. Douze, and H. Jégou, "Billion-Scale Similarity Search with GPUs," *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [22] S. Robertson and H. Zaragoza, "The Probabilistic Relevance Framework: BM25 and Beyond," *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
- [23] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods," in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [24] R. Pandey and A. Bhujang, "Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content," *arXiv preprint arXiv:2605.24421*, 2026.
- [25] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-Hashing for Message Authentication," Internet Engineering Task Force, RFC 2104, 1997.
- [26] J. Zhang *et al.*, "When LLMs Meet Cybersecurity: A Systematic Literature Review," *Cybersecurity*, vol. 8, 2025.
- [27] B. A. AlAhmadi, L. Axon, and I. Martinovic, "99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms," in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [28] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An Agentic RAG cyber attack classification and reporting tool," *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [29] Z. Liu and A. Anwar, "AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation," *arXiv preprint arXiv:2508.13118*, 2025.
- [30] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, "LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations," *arXiv preprint arXiv:2604.05440*, 2026.
- [31] R. Sahay *et al.*, "Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage," *arXiv preprint arXiv:2603.23966*, 2026.
- [32] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, "Drain: An Online Log Parsing Approach with Fixed Depth Tree," in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [33] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy," The MITRE Corporation,

Technical Report MP180360, 2018.

- [34] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [35] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [36] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
- [37] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [38] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.